

Company: Alvin Tech

Information Security Policy

Version: 3.0

Effective Date: March 1, 2025

Last Updated: February 15, 2025

Approved by: Board of Directors

Table of Contents

1. Introduction
2. Scope
3. Information Classification
4. Access Control
5. System Security
6. Network Security
7. Data Protection
8. Incident Response
9. Business Continuity
10. Compliance
11. Vendor Management
12. Enforcement

1. Introduction

1.1 Purpose

This Information Security Policy defines the requirements for protecting Alvin Tech's information assets, systems, and customer data. This policy has been updated to address regulatory findings and align with PCI DSS requirements.

1.2 Background

Alvin Tech provides virtual card services and wallet management solutions to consumers and businesses. As a fintech company handling sensitive financial information, we are committed to maintaining the highest standards of information security.

1.3 Policy Statement

Alvin Tech is committed to protecting the confidentiality, integrity, and availability of all information assets. This policy establishes the framework for information security management within the organization.

2. Scope

2.1 Applicability

This policy applies to:

- All employees, contractors, and temporary staff
- All information systems owned or operated by Alvin Tech
- All information created, stored, processed, or transmitted by Alvin Tech
- All third-party vendors and service providers

2.2 Policy Review

This policy shall be reviewed annually or when significant changes occur in the business, regulatory environment, or threat landscape.

3. Information Classification

3.1 Classification Levels

Alvin Tech information shall be classified into the following categories:

- **Restricted:** Highly sensitive information (e.g., cardholder data, authentication credentials)
- **Confidential:** Sensitive business information (e.g., customer lists, financial data)
- **Internal:** Information for internal use only
- **Public:** Information approved for public disclosure

4. Access Control

4.1 Access Management Principles

- Access shall be granted based on the principle of least privilege
- Access rights shall be reviewed quarterly
- All access must be authenticated and authorized

4.2 Authentication Requirements

- Multi-factor authentication (MFA) is required for all administrative access
- MFA is required for remote access to the network
- Minimum password length must be 10 characters
- Password validation must be case sensitive
- A password must have a combination of all the following character sets: upper case letters, lower case letters, numbers, special characters
- Password hashing algorithm must be at least SHA-256 or higher
- Hardcoded passwords must not be used

4.3 Privileged Access Management

- Privileged accounts shall be inventoried and monitored
- Privileged access shall be granted through a formal approval process
- Privileged account usage shall be logged and reviewed

4.4 User Access Reviews

- Managers shall review user access rights quarterly
- HR shall notify IT of personnel changes affecting access requirements
- Terminated employee access shall be revoked immediately

5. System Security

5.1 Secure Configuration

- Systems shall be hardened according to industry standards
- Default accounts and passwords shall be changed before production deployment
- Unnecessary services and ports shall be disabled

5.2 Patching and Updates

- Critical security patches shall be applied within 14 days of release
- All other security patches shall be applied within 30 days
- Exceptions must be documented and approved

5.3 Malware Protection

- Anti-malware solutions shall be deployed on all systems

- Malware signatures shall be updated daily
- Malware alerts shall be investigated promptly

6. Network Security

6.1 Network Architecture

- Networks shall be segmented based on security requirements
- Firewalls shall be deployed at network boundaries
- Internal firewalls shall segment sensitive environments

6.2 Remote Access

- VPN with MFA is required for remote access
- Remote sessions shall time out after 30 minutes of inactivity
- Remote access shall be logged and monitored

6.3 Wireless Security

- Wireless networks shall use WPA2-Enterprise or stronger encryption
- Guest wireless networks shall be segregated from internal networks
- Wireless access points shall be securely configured

7. Data Protection

7.1 Data Encryption

- Cardholder data shall be encrypted at rest using AES-256
- Sensitive data in transit shall be encrypted using TLS 1.2 or higher
- Encryption keys shall be managed according to PCI DSS requirements

7.2 Data Retention

- Data shall be retained only as long as necessary for business purposes
- Retention periods shall comply with legal and regulatory requirements
- Data disposal shall render information unrecoverable

7.3 Data Loss Prevention

- DLP solutions shall be deployed to prevent unauthorized data transfers

- DLP alerts shall be investigated promptly
- Users shall be trained on data handling procedures

8. Incident Response

8.1 Incident Reporting

- Security incidents shall be reported immediately to the Security Operations Center
- An incident response plan shall be maintained and tested annually
- Lessons learned shall be incorporated into security practices

8.2 Incident Handling

- The Incident Response Team shall be trained and prepared to respond
- Incidents shall be classified and prioritized based on severity
- Communication procedures are defined in the Incident Response Plan

8.3 Forensic Investigations

- Evidence shall be collected and preserved according to forensic best practices
- Chain of custody shall be maintained for all evidence
- Investigations shall be conducted by qualified personnel

9. Business Continuity

9.1 Backup Procedures

- Critical systems shall be backed up daily
- Backups shall be tested quarterly
- Offsite backup storage shall be maintained

9.2 Disaster Recovery

- A disaster recovery plan shall be maintained and tested annually
- Recovery time objectives (RTOs) shall be defined for critical systems
- Alternate processing facilities shall be available

10. Compliance

10.1 Regulatory Compliance

- Alvin Tech shall comply with all applicable laws and regulations
- PCI DSS compliance shall be maintained for card processing systems
- Compliance status shall be reviewed quarterly

10.2 Auditing and Monitoring

- Security logs shall be retained for at least one year
- Access to sensitive systems shall be logged and monitored
- Regular vulnerability assessments shall be conducted

10.3 Training and Awareness

- All employees shall receive security awareness training annually
- Specialized training shall be provided for security-related roles
- Security awareness communications shall be provided regularly

11. Vendor Management

11.1 Vendor Due Diligence

- Security assessments shall be conducted prior to engaging vendors
- Vendors shall comply with Alvin Tech security requirements
- Vendor access shall be limited to necessary systems

11.2 Vendor Contracts

- Security requirements shall be included in all vendor contracts
- Right to audit shall be reserved for critical vendors
- Breach notification requirements shall be specified

12. Enforcement

12.1 Policy Violations

- Violations of this policy may result in disciplinary action
- Violations shall be reported to management
- Intentional violations may result in termination

12.2 Exceptions

- Exceptions to this policy must be approved by the CISO (Chief Information Security Officer)
- Exceptions shall be documented and reviewed quarterly
- Compensating controls shall be implemented for exceptions

Revision History

Version	Date	Description	Approved By
1.0	Jan 15, 2023	Initial policy	Board of Directors
2.0	Oct 10, 2024	Updated for regulatory compliance	Board of Directors
3.0	Feb 15, 2025	Major revision addressing audit findings	Board of Directors